INF1050 - Política de gestión de identidades digitales, credenciales y accesos

Proyecto	Autor
ISBE	Yeray Rodríguez Rodríguez

Fecha	Colaboradores
15.10.2025	Florentín Pérez González Alberto Rodríguez Ludeiro Iraia Olabarrieta Eduardo

Financiado por la Unión Europea NextGenerationEU
Gobierno de España Ministerio para la Transformación Digital y de la Función Pública
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid
ALASTRIA

Índice

1. Objeto y alcance 4
2. Definiciones y marco de referencia 6
2.1 Definiciones clave 6
2.2 Marco de referencia 7
2.3 Reglas de interpretación 7
3. Principios 8
4. Roles y responsabilidades 10
4.1 Roles del ecosistema 10
4.2 Matriz RACI 11
5. Reglas obligatorias 13
5.1 Representación de la entidad - VC LEAR 13
5.2 Personas operativas - VC Empleado (rol operativo) 14
5.3 Vinculación con accesos (Identidad = Acceso) 15
5.4 Publicación en registros 15
5.5 Gestión de excepciones 16
5.6 Uso operativo de identificadores (DID) 16
6. Procedimientos clave 18
6.1 Enrolamiento ISBE (off-chain) 18
6.2 Enrolamiento on-chain 19
6.3 Emisión de credenciales LEAR 21
Ámbito / Roles 21
Entradas 21
Pasos 21
Salidas 21
Plazos / SLAs 22
Evidencias 22
6.4 Alta, cambio y baja de Representante (VC LEAR) 22
6.5 Alta, cambio y baja de Persona operativa (VC Empleado) 23
6.6 Suspensión preventiva (riesgo o incumplimiento) 23
6.7 Baja (offboarding) 24
6.8 Gestión de incidentes de identidad (credenciales, accesos, mapeo) 25
6.9 Revisión periódica (anual o por evento) 26

7. Supervisión, revisión y actualización 27
7.1 Objetivo y alcance de la supervisión 27
7.2 Reporting operativo (paneles y periodicidad) 27
7.3 Indicadores y umbrales (KPI mínimos) 27
7.4 Auditorías (ordinarias y ad-hoc) 28
7.5 Medidas correctoras y escalado 28
7.6 Revisión y actualización de INF1050 (periodicidad y triggers) 28
7.7 Gestión de versiones y comunicación 28
7.8 Resumen práctico de roles en la supervisión 29
8. Anexos 30

1. Objeto y alcance

Esta política establece las reglas obligatorias para la gestión de identidades digitales, las credenciales que las representan y su vinculación con los accesos operativos en ISBE. Su finalidad es que toda alta, cambio, suspensión o baja de identidades y credenciales se realice con criterios uniformes, privacidad por diseño y trazabilidad auditables, evitando ambigüedades y accesos residuales.

Resultados esperados

- Identificación única y verificable de los participantes.
- Uso coherente de credenciales (p. ej., VC LEAR para representación; VC Empleado para roles operativos).
- Propagación automática del estado de la credencial a los accesos (concesión, suspensión, baja).
- Evidencias mínimas y no personales para auditoría y supervisión.

Ámbito de aplicación

Esta política aplica a:

- Participantes de ISBE.
- Sus representantes (titulares de VC LEAR).
- Personas operativas (titulares de VC Empleado) e identidades de servicio que actúen sobre la red o servicios ISBE.
- Controladores de dominio, Emisores confiables (TI) y Verificadores confiables (TV) en lo relativo a requisitos de identidad y credenciales.
- Todos los entornos (preproducción y producción) y dominios/TA aprobados dentro de ISBE.

Relación con otros documentos

- **Entregable de Artefactos – Apartado 3:** definen formatos, protocolos y mecanismos técnicos.

- Política de adhesión al, y salida del, ecosistema ISBE (ISBE, ECO1010).

En materia de **identidad, credenciales y accesos**, **INF1050 prevalece** sobre cualquier contradicción en otros documentos.

Marco de referencia

La aplicación de esta política se alinea con:

- **EUDIW/ARF y eIDAS 2.0** (interoperabilidad y reconocimiento europeo de credenciales).
- **RGPD** (minimización y ausencia de datos personales en la red).
- **NIS2** (control de accesos y segregación de funciones).

Fuera de alcance

- Detalle técnico de métodos DID, formatos o APIs.
- Especificaciones de gestión criptográfica a nivel de sistema, más allá de las exigencias de custodia y rotación que se impongan desde seguridad.
- Políticas laborales internas de las entidades miembro.
- Contenido semántico de credenciales específico de cada caso de uso (se rige por las políticas del dominio/TA en el Trust Framework).

*(Los **principios** que rigen esta política se desarrollan en el punto 3. Los **roles y responsabilidades**, en el punto 4.)*

2. Definiciones y marco de referencia

2.1 Definiciones clave

- **Identidad del Participante o miembro (entidad):** reconocimiento institucional de una persona jurídica como miembro de ISBE, con un estado publicado (vigente/suspendido/baja) y un conjunto de representantes y personas operativas asociadas.
- **DID:isbe (identificador descentralizado).** Identificador recomendado por ISBE para publicar la identidad de los miembros y de sus servicios en los registros de confianza. Podrán usarse otros métodos DID por interoperabilidad, siempre que exista mapeo verificable a DID:isbe en los catálogos del marco.
- **Representante autorizado (VC LEAR):** persona física que puede actuar en nombre de la entidad. Su capacidad se prueba mediante una credencial verificable de representación (VC LEAR) vigente. LEAR significa Representante Designado de la Entidad Legal.
- **Persona operativa (VC Empleado):** persona física que desempeña un rol operativo (por ejemplo, operación de servicios).
- **Identidad de servicio:** identidad asignada a un sistema o aplicación de la entidad (no a una persona), con permisos limitados al servicio que presta.
- **Dominio de confianza:** ámbito de operación (sector/caso de uso) con reglas comunes, propietario/controlador y un Trust Anchor (TA) como punto de referencia de confianza.
- **Trust Anchor (TA):** anclaje de confianza que reconoce a emisores/verificadores válidos dentro de un dominio y desde el cual se delegan autorizaciones.
- **LoA – Nivel de Garantía:** nivel de exigencia (bajo/medio/alto, u otro esquema equivalente) que el dominio requiere para emitir/aceptar credenciales; fija evidencias mínimas y controles.
- **Emisor confiable (TI):** entidad autorizada en el dominio para emitir credenciales.
- **Verificador confiable (TV):** entidad autorizada en el dominio para solicitar y validar credenciales; debe registrar evidencia mínima de la verificación.
- **Evidencia mínima de verificación:** registro no personal que deja constancia de que una credencial fue verificada (qué, cuándo, bajo qué política), suficiente para auditoría.
- **Publicación sin PII:** publicación de hechos (estatus de miembro, vigencia de roles o acreditaciones) sin datos personales, preservando privacidad.
- **Listas/Registros de confianza:** publicaciones oficiales del marco (registro raíz y registros de dominio) con estados vigentes de dominios, emisores, verificadores y tipos de credenciales aceptadas.
- **Suspensión / Baja:** medidas de gobierno sobre identidades o acreditaciones.
    - **Suspensión:** medida *temporal* ante riesgo/incumplimiento con plan de remediación.
    - **Baja:** pérdida *definitiva* de la condición o del rol/acreditación.

2.2 Marco de referencia

- **EUDIW / ARF (European Digital Identity Wallet / Architecture & Reference Framework):** referencia europea para emisión y presentación de credenciales interoperables. A efectos de esta política, se toma como alineamiento por defecto para formatos, flujos y etiquetas de confianza.
- **EBSI (European Blockchain Services Infrastructure):** marco europeo de referencia para ecosistemas de credenciales y trazabilidad; se adopta compatibilidad cuando proceda.
- **eIDAS 2.0:** Reglamento europeo que establece el marco legal de identidad digital y servicios de confianza introduce las acreditaciones cualificadas de atributos, y obliga al reconocimiento transfronterizo de medios de identificación notificados y de servicios cualificados en la UE. La European Digital Identity Wallet (EUDIW) surge para ofrecer una solución compatible con eIDAS. Para esta política, es la referencia jurídica base.
- **RGPD:** base para privacidad por diseño: minimización de datos, licitud de tratamiento y no publicación de PII en la red.
- **NIS2:** referencia para controles de acceso, segregación de funciones y resiliencia operativa, aplicables a la gestión de identidades y credenciales.

2.3 Reglas de interpretación

- **Prioridad documental:** cuando exista contradicción en materia de identidad, credenciales y accesos, *prevalece INF1050* sobre documentos de igual o menor rango.
- **Alineamiento europeo:** ante divergencias entre guías EBSI y EUDIW/ARF, esta política prioriza EUDIW/ARF por su proximidad a eIDAS 2.0, sin renunciar a la compatibilidad con EBSI.
- **Privacidad y evidencia:** toda obligación de publicación y trazabilidad se cumple sin PII, dejando evidencias mínimas suficientes para auditoría.
- **Competencias:** el Trust Framework decide quién puede emitir/verificar en cada dominio (autoridad, LoA, registros); INF1050 regula qué credenciales de identidad se exigen, cómo se gestionan y cómo impactan en los accesos.

3. Principios

Estos principios orientan todas las decisiones y procedimientos de INF1050. Sirven como guía para resolver dudas y priorizar medidas.

1. **Alineación europea por defecto**
   Las identidades y credenciales se gestionan conforme a eIDAS 2.0 y a los perfiles EUDIW/ARF; se mantiene la compatibilidad con EBSI cuando aplique. Ante divergencias, se prioriza EUDIW/ARF.
2. **Privacidad por diseño**
   No se publican **datos personales** en la red. Se aplican minimización y limitación de finalidad; solo se generan evidencias no personales suficientes para auditar.
3. **Proporcionalidad y nivel de garantía (LoA)**
   Las exigencias de identidad y credenciales se ajustan al riesgo del caso de uso. A mayor impacto, mayor LoA y controles (revisiones, evidencias, doble validación).
4. **Menor privilegio y segregación de funciones**
   Nadie dispone de más permisos de los necesarios y se separan quien autoriza, quien emite/verifica y quien opera. Reduce fraude y errores (alineado con NIS2).
5. **Coherencia identidad–accesos**
   El **estado** de las credenciales (vigente, suspendida, revocada) se propaga automáticamente a los accesos operativos. Sin credencial válida, no hay acceso.
6. **Trazabilidad mínima y auditabilidad**
   Toda alta, cambio, suspensión y baja deja una evidencia verificable (no personal) con quién, qué, cuándo y bajo qué regla, suficiente para auditoría y control.
7. **Transparencia controlada**
   Se publican en registros los hechos esenciales (estatus del miembro, actores autorizados, estados), sin PII, con histórico de cambios y versionado de políticas.
8. **Neutralidad tecnológica e independencia de método**
   La política no impone una tecnología concreta. El modelo de identidad es agnóstico al método de identificador y a la implementación, siempre que cumpla estos principios.
9. **Evolución sin ruptura**
   Los cambios se gestionan con versionado, ventanas de gracia y guías de migración para no interrumpir servicios ni invalidar integraciones existentes.
10. **Responsabilidad y rendición de cuentas**
    Cada actor responde de su parte (miembro, representante, empleado, dominio).
11. **Interoperabilidad y portabilidad**
    Las credenciales se diseñan para ser aceptadas entre dominios y por terceros europeos cuando corresponda.
12. **Gestión de incidentes y mejora continua**
    Cualquier incidente de identidad/credenciales activa **medidas proporcionales** (suspensión, remediación) y alimenta un ciclo de lecciones aprendidas.

Cómo se aplica: Ante cualquier decisión (p. ej., quién puede emitir una VC Empleado de rol crítico, cuánto dura una suspensión, qué se publica en un registro), se evalúa el riesgo, el LoA requerido, el

impacto en privacidad y la capacidad de trazabilidad. Si hay conflicto entre soluciones, se elige la que cumpla eIDAS/ARF, minimice datos, garantice menor privilegio y asegure evidencias auditables con menor fricción para los miembros.

4. Roles y responsabilidades

Este apartado define quién hace qué en la gestión de identidades, credenciales y accesos bajo INF1050. Cuando un rol pertenezca a un *dominio de confianza*, su actuación debe además cumplir las reglas del **Trust Framework** (6.20).

4.1 Roles del ecosistema

Este apartado enumera los *roles que intervienen en la aplicación de INF1050*. No se distingue entre roles "institucionales" y "técnicos" en esta política: todos se describen desde la gobernanza (quién decide, qué hace y con qué responsabilidades).

- **Entidad Gestora ISBE**
  - **Responsabilidad principal:** Custodiar esta política y asegurar su aplicación homogénea.
  - **Funciones:** Aprobar altas/bajas de miembros de primer nivel; validar la existencia y vigencia de representantes; ordenar suspensiones por riesgo o incumplimiento; resolver excepciones; publicar el estatus de miembro.
- **Controlador de dominio (propietario de un sector de actividad o caso de uso)**
  - **Responsabilidad principal:** Asegurar y supervisar el cumplimiento de los requisitos de identidad y credenciales definidos en INF1050.
  - **Funciones:** proponer altas/bajas de TI/TV; revisar evidencias de representación y de rol; mantener al día el registro del dominio (actores y estados).
- **Participante (persona jurídica), actuando a través de su Representante (titular de VC LEAR)**
  - **Responsabilidad principal:** mantener correcta y vigente su identidad institucional y la de sus personas autorizadas, actuando siempre por medio de un Representante con VC LEAR vigente.
  - **Funciones:**
    - Designar y mantener Representante(s) con VC LEAR; comunicar altas/cambios/bajas.
    - Solicitar/renovar VC Empleado para personas operativas según el dominio.
    - Custodiar claves y accesos asociados a sus identidades.
    - Atender revisiones y requerimientos de la Entidad Gestora/Controlador de dominio.

  Nota: Cuando el Participante sea *persona física* (casos excepcionales, autónomos), el titular coincide con el Representante; en estos casos se documenta como *"LEAR = Participante"*.
- **Persona operativa (titular de VC Empleado)**
  - **Responsabilidad principal:** operar en la red con el rol y alcance que indique su credencial.
  - **Funciones:** usar la credencial vigente; cumplir segregación de funciones; reportar incidencias que afecten a su identidad/accesos.
- **Emisor confiable (Trusted Issuer, TI)**
  - **Responsabilidad principal:** emitir credenciales (p. ej., VC Empleado con rol crítico) conforme a las reglas del dominio y a INF1050.

- **Funciones:** comprobar representación y vínculo con el Participante; definir vigencia y estado; publicar cambios de estado en los registros correspondientes.
- **Verificador confiable (Trusted Verifier, TV)**
  - **Responsabilidad principal:** validar credenciales antes de autorizar una operación.
  - **Funciones:** verificar emisor habilitado y estado de la credencial; registrar evidencia mínima de la verificación.
- **Comité de Procesos y Gestión de Riesgos**
  - **Responsabilidad principal:** verificar la aplicación de INF1050.
  - **Funciones:** revisar evidencias, muestrear decisiones de alta/cambio/suspensión/baja; proponer medidas correctoras.

4.2 Matriz RACI

Proceso / Decisión	ISBE	Controlador dominio	Participante (a través de su Representante LEAR)	Persona operativa	TI	TV	Comité de Procesos y Gestión de Riesgos
Alta de miembro	A	I	R	—	—	—	I
Publicación estatus de miembro	A	I	R	—	—	—	I
Alta/cambio/baja de LEAR	A	I	R	—	—	—	I
Alta/cambio/baja de VC Empleado	I	C	R	I	C	I	I
Suspensión por riesgo/incumplimiento	A	C	R	I	C	C	I
Baja y retirada de accesos	A	C	R	I	C	C	I
Evidencia mínima de verificación	I	C	—	—	—	R	I

Leyenda:

Sigla	Significado	Descripción breve
A	*Accountable*	Aprueba/decide la acción y asume la responsabilidad final.

R	*Responsible*	Ejecuta la acción.
C	*Consulted*	Consulta preceptiva antes de decidir/ejecutar.
I	*Informed*	Informado del resultado/decisión.

5. Reglas obligatorias

Estas reglas son de **cumplimiento obligatorio** para todos los participantes. Cuando un dominio de confianza establezca requisitos adicionales, **se aplican ambos.**

5.1 Representación de la entidad - VC LEAR

Regla 1. Obligación de representación.

Toda actuación en nombre del Participante ante ISBE (solicitudes de alta/cambio/baja, creación de identidades de servicio, peticiones de VC Empleado, etc.) se canaliza siempre a través de un Representante con VC LEAR vigente.

Regla 2. Emisión.

La VC LEAR la emite un Emisor confiable (TI) autorizado por ISBE o por el dominio competente para identidad corporativa. Queda prohibida la auto-emisión de la VC LEAR por el propio Participante (debido al alcance del proyecto, ya que una VC LEAR podría ser auto emitida bajo ciertas condiciones).

Regla 3. Vigencia y renovación.

- **Vigencia máxima:** 24 meses.
- **Renovación:** debe solicitarse con al menos 30 días naturales de antelación a la fecha de expiración.
- La VC LEAR puede tener vigencia menor si así lo fija el dominio.

Regla 4. Revocación y suspensión.

- **Revocación inmediata** cuando cese el poder de representación o se detecte uso indebido.
- **Suspensión preventiva** ante dudas razonables (fraude, conflicto, incoherencia documental).
- **Propagación a accesos:** la pérdida de validez (suspensión o revocación) se reflejará en los accesos en un plazo máximo de 2 horas.

Regla 5. Multiplicidad y límites.

- Puede haber varios Representantes por Participante, cada uno con su VC LEAR vigente.
- Ningún Representante puede delegar sus poderes sin que exista traza y evidencia de esa delegación conforme a la política del dominio.

Regla 6. Evidencias y publicación.

- La emisión, suspensión o revocación de VC LEAR generará evidencia mínima (qué, quién, cuándo y bajo qué regla), sin datos personales.

5.2 Personas operativas - VC Empleado (rol operativo)

Regla 7. Obligación de credencial de rol.

Toda persona que opere en ISBE debe contar con *VC Empleado vigente* que indique *capacidades* (operador, desarrollador). Esto se refleja como una serie de poderes dentro de la credencial LEAR.

Regla 8. Clasificación de roles

Cada rol operativo deberá clasificarse como **crítico o no crítico** antes de emitir la VC Empleado correspondiente.

Es **crítico** si se cumple *al menos uno* de estos criterios:

a) Opera componentes esenciales del dominio o de la red.
b) Su fallo podría causar impacto regulatorio, interrupción de servicio o riesgo sistémico en el dominio.
c) Gestiona material que confiere efectos jurídicos u operativos significativos.

Es no crítico cuando *no concurre* ninguno de los supuestos anteriores y el rol se limita a:

- Tareas internas sin firma/validación frente a terceros.
- Sin administración de permisos de otros.
- Sin afectación a disponibilidad/seguridad del dominio o red.

Regla 9. Quién emite la VC Empleado.

- La VC Empleado la emite un TI autorizado.

Regla 10. Alcance y cambios.

- El alcance del rol será expreso y limitado a las tareas necesarias.
- Cambio de rol o de alcance ⇒ nueva VC o actualización con registro y evidencia.

Regla 11. Vigencia, revisión y baja.

- **Vigencia máxima:** 12 meses (o menor si lo fija el dominio).
- **Revisión:** al menos anual o por evento (cambio de funciones, cese, incidente).
- **Baja obligatoria:** cese del vínculo, incumplimiento o fraude ⇒ revocación inmediata y retirada de accesos.

Regla 12. Evidencias y publicación.

- Emisión/cambio/suspensión/revocación dejan evidencia mínima.
- Se publica el hecho de que el Participante tiene personas operativas habilitadas por rol y sus estados (vigente/suspendido/baja).

Regla 13. Prohibiciones.

- No se permite el acceso a cualquier VC caducada o revocada
- Reutilizar una VC Empleado para otro rol u otro dominio distinto al indicado.
- Compartir credenciales entre personas o usarlas para fines distintos del alcance aprobado.

5.3 Vinculación con accesos (Identidad = Acceso)

Regla 14. Propagación automática.

El estado de las credenciales (VC LEAR y VC Empleado) gobierna automáticamente los accesos operativos:

- **Vigente** ⇒ acceso habilitado según alcance.
- **Suspendida** ⇒ acceso bloqueado hasta resolución.
- **Revocada** ⇒ acceso retirado.
- **Caducada** => acceso retirado.

Regla 15. Plazos máximos.

- La propagación de suspensiones/revocaciones a accesos se realizará en un plazo máximo de 2 horas desde la decisión.
- El alta de accesos es automática e inmediata, salvo en dominios de alto riesgo, donde podrá demorarse hasta fin del día hábil para completar verificaciones adicionales.

Regla 16. Denegación por defecto.

En caso de inconsistencia o falta de sincronización, se aplicará denegación por defecto hasta aclaración (seguridad > conveniencia).

Regla 17. Mapeo y control.

Cada Participante mantendrá un mapeo actualizado entre credenciales y permisos; cualquier cambio de estado debe reflejarse en accesos. El Controlador de dominio puede requerir evidencias de este mapeo.

5.4 Publicación en registros

Regla 18. Qué se publica.

- **Registro raíz (ISBE):** dominios/TA aprobados, controladores y políticas vigentes.
- **Registros de dominio:** hecho de miembros con roles habilitados y estados (vigente/suspendido/baja), esquemas admitidos y LoA.

ISBE no mantiene un registro único y exhaustivo de TI/TV; la confianza se resuelve gracias a la cadena de confianza mediante DIDs y credenciales verificables. No existe obligación de un registro único formal: la validez se determina criptográficamente y por políticas de confianza publicadas por ISBE.

Regla 19. Cómo se publica.

- **Sin datos personales** (solo hechos institucionales).
- **Actualización inmediata** tras cada decisión y consolidación diaria en caso de lotes.
- **Histórico de cambios** y **versionado.** Las cadenas de confianza no tienen por qué guardarse dentro de la propia red, sino que se pueden gestionar externamente para aportar mayor privacidad al caso de uso. En esos casos, no se puede garantizar ni el histórico ni el versionado.

Regla 20. Calidad y coherencia.

La información publicada debe ser exacta y completa. Cualquier discrepancia se corregirá sin demora y dejará traza de la enmienda.

5.5 Gestión de excepciones

Regla 21. Solicitud y aprobación.

Las excepciones a esta política se solicitarán por el Participante a través de su Representante (VC LEAR), con justificación, alcance, riesgos y medidas compensatorias. La Entidad Gestora ISBE es quien aprueba o rechaza.

Regla 22. Duración y control.

- **Vigencia máxima de una excepción**: 90 días naturales.
- La excepción incluirá **condiciones de control** y **fecha de revisión**.
- **No prorrogable** sin nueva resolución motivada.

Regla 23. Materias sin excepciones.

No se concederán excepciones que vulneren: privacidad por diseño (p. ej., publicación de PII en la red), propagación de estados a accesos (Identidad = Acceso), LoA mínimos de roles críticos o evidencia mínima y trazabilidad.

Regla 24. Publicidad.

Se publicará el hecho de que una excepción ha sido concedida, con vigencia y ámbito, en el registro correspondiente.

5.6 Uso operativo de identificadores (DID)

Regla 25. Identificador operativo. Cada miembro deberá mantener un DID:isbe vigente para su identidad organizativa.

Regla 26. Ciclo de vida y evidencias. Las altas y bajas de DIDs se registrarán con evidencia mínima (qué, quién, cuándo y bajo qué regla), y se publicará el hecho y el estado en los registros (ver 5.4).

Regla 27. Publicación y coherencia por dominio. El registro del dominio publicará el DID de TI/TV y miembros activos. Los cambios de estado deberán reflejarse sin demora.

Regla 28. Interoperabilidad. Un dominio podrá aceptar otros métodos DID si el mapeo a DID:isbe es verificable y mantiene la trazabilidad exigida por esta política.

6. Procedimientos clave

Estos procedimientos se publican en el Portal de Gobierno ISBE, sección *Políticas y Procedimientos Operativos* > *Gestión de Identidades y Onboarding*, y se actualizan bajo la política *INF1050 – Política de gestión de identidades digitales, credenciales y accesos*.

Nota: La interoperabilidad se garantiza mediante APIs REST y mensajería JSON conformes a los estándares W3C DID y Verifiable Credentials (VC). Esta alineación técnica permite la integración transparente con otras infraestructuras europeas de identidad soberana y con los marcos de interoperabilidad de EBSI y eIDAS 2.0.

6.1 Enrolamiento ISBE (off-chain)

Objetivo. Gestionar el alta inicial de entidades participantes en ISBE, verificando la identidad del representante legal mediante certificado cualificado eIDAS y estableciendo la relación contractual, técnica y de gobernanza necesaria para su incorporación a la red.

Ámbito / Roles

- **Solicitante:** representante legal de la entidad, titular de un certificado cualificado eIDAS (FNMT u otro QTSP).
- **Sistema ISBE (Portal / IdP):** automatiza las validaciones, consentimientos y creación de usuario.
- **Administrador ISBE:** supervisa la correcta incorporación y conserva las evidencias de alta.
- **Gestor jurídico / gobernanza:** valida la firma de contratos y acuerdos operativos.

Entradas

- Certificado cualificado eIDAS del representante legal (formato X.509).
- Datos de la entidad (razón social, NIF, dirección, contacto).
- Correo electrónico operativo para comunicación y validación.
- Consentimiento GDPR firmado digitalmente.
- Contratos y acuerdos de adhesión (GPs/SLAs).

Pasos

1. **Inicio del alta:** acceso del usuario al portal ISBE y selección del método de registro (certificado de empresa).
2. **Presentación de certificado cualificado:** carga y lectura del certificado eIDAS en formato x509 (FNMT u otro QTSP).
3. **Validación del certificado:** verificación automática de autenticidad, emisor y vigencia.
4. **Registro de correo electrónico:** introducción del e-mail principal de contacto.
5. **Verificación de correo:** envío de enlace de confirmación y validación.
6. **Firma digital de acuerdos operativos:** Suscripción simultánea del Contrato Marco y de, al menos, un Anexo de Rol relativo a uno de los Niveles de Participación disponibles.

7. **Creación de usuario en IdP ISBE:** alta automática vinculada al certificado validado. El nombre de usuario será el correo electrónico.
8. **Alta de la empresa en BBDD ISBE:** registro de los metadatos de identidad y permisos.
9. **Confirmación de alta:** envío de mensaje de bienvenida y acceso a la plataforma.

Salidas

- Usuario autenticado en el IdP ISBE.
- Entidad verificada y registrada en la base de datos ISBE.
- Consentimiento y contratos archivados.
- Habilitación para enrolamiento on-chain posterior (asignación de DID:isbe).

Plazos / SLAs

- Validación automática del certificado y correo: ≤ 5 minutos.
- Revisión manual (si procede): ≤ 2 días hábiles.
- Confirmación de alta y acceso: ≤ 24 horas tras firma digital.

Evidencias

- Registro del certificado cualificado (hash y metadatos).
- Log de validaciones y consentimientos GDPR.
- Copia electrónica de los acuerdos firmados.
- Entrada en el registro de entidades ISBE.
- Correo de confirmación y trazabilidad de la transacción de alta.

6.2 Enrolamiento on-chain

Objeto. Registrar y activar los identificadores descentralizados (**DID:isbe**) de las entidades previamente validadas en el proceso de enrolamiento ISBE, permitiendo su operatividad dentro de las redes *blockchain* de casos de uso (genérico o financiero). El proceso garantiza la trazabilidad, autenticidad y vinculación con los metadatos eIDAS del representante legal.

Ámbito / Roles

- **Usuario autenticado:** representante legal o técnico autorizado con certificado cualificado eIDAS.
- **CLI ISBE / Módulo de enrolamiento:** permite la generación del identificador del DID y la prueba que permite demostrar su asociación a las claves.
- **QTSP (Qualified Trust Service Provider):** firma y sella transacciones.
- **Administrador ISBE:** El admin verifica que la transacción haya finalizado con éxito

Entradas

- Certificado cualificado eIDAS (autenticación y metadatos ((organizationName, organizationIdentifier)). LEI se obtendrá online.
- Par de claves pública-privada generado offline.
- Tipo de enrolamiento seleccionado (genérico (secp256k1) o financiero (secp256r1).
- Consentimiento y alta previa completada (enrolamiento ISBE).

Pasos

1. **Autenticación:** el usuario accede al CLI ISBE logueado con su certificado cualificado.
2. **Selección de tipo de caso de uso:** elección entre enrolamiento en la red de casos de uso financiera (R1) o genérica (K1).
3. **Generación de par de claves:** creación offline de claves pública y privada según el tipo de enrolamiento.
4. **Registro de clave pública:** inclusión manual en el formulario para asociarla al futuro DID Document.
5. **Autogeneración del identificador `did:isbe`:** creación local del DID mediante el CLI.
6. **Generación de borradores de DID Document (UC / FinUC):** el sistema crea una versión preliminar del DID Document (pantalla de confirmación de datos).
   Incorporación de metadatos eIDAS:
   a. `urn:oid:2.5.4.10` → nombre de organización.
   b. `urn:oid:2.5.4.97` → identificador de organización (VAT/Tax ID).
   c. `urn:lei` → identificador LEI, obtenido vía API pública ya que no se incluye en el certificado de representante.
7. **Revisión y aprobación del DID:** el usuario valida el contenido del DID Document antes de la transmisión.
8. **Firma y envío de transacciones al DID Registry:** las Tx se firman y sellan on-chain por un QTSP.
9. **Registro/actualización on-chain:** los DIDs quedan inscritos en la blockchain correspondiente.
10. **Confirmación final:** notificación al usuario y verificación de estado activo de los DIDs.

Salidas

- Identificadores `did:isbe` creados y activos (R1 o K1).
- DID Documents registrados y accesibles en blockchain.
- Firma asociada a cada transacción.
- Log de validación eIDAS y metadatos asociados.

Plazos / SLAs

- Generación y firma local: inmediata (< 5 min).
- Validación y registro on-chain: ≤ 1 hora (dependiente de la red).
- Confirmación de alta de DIDs: ≤ 24 horas tras recepción de Tx.

Evidencias

- Hash de transacciones registradas en la red (Bare/UC).
- DID Document publicado y verificable.
- Log de ejecución del CLI ISBE.
- Confirmación electrónica de éxito del QTSP.

6.3 Emisión de credenciales LEAR

Objeto. Emitir credenciales verificables (**VC LEAR**) que acrediten la condición de **Legal Entity Appointed Representative (LEAR)** de una entidad participante en ISBE, vinculando de forma segura la identidad eIDAS del representante con su wallet personal. El proceso permite también la emisión de credenciales de tipo *Employee*, bajo la misma política de estatus y revocación.

Ámbito / Roles

- **Usuario LEAR:** representante legal autenticado mediante certificado cualificado eIDAS.
- **Portal ISBE:** punto de acceso para solicitar la credencial.
- **Wallet Connector (ISBE-ART-00101):** componente institucional que genera y firma las credenciales.
- **Wallet personal (usuario):** destino final de la VC LEAR o Employee.
- **Administrador ISBE:** mantiene la base de datos de entidades y supervisa la trazabilidad de emisión.

Entradas

- Certificado eIDAS del representante (para autenticación).
- Datos de la empresa previamente registrados en la base de datos ISBE.
- Petición explícita de emisión de credencial LEAR o Employee.
- Esquema de credenciales y metadatos de emisión definidos por ISBE.

Pasos

1. **Login en ISBE:** acceso autenticado del usuario mediante certificado cualificado eIDAS.
2. **Solicitud de emisión:** el usuario solicita la VC LEAR a través del portal ISBE.
3. **Verificación de datos:** el sistema comprueba que los datos de la entidad están registrados en la BBDD ISBE.
4. **Emisión por Wallet Connector:**
    a. Generación de la credencial LEAR con los datos verificados.
    b. Firma de la VC por el conector institucional con su clave cualificada.
5. **Entrega a wallet personal:** envío de la VC LEAR al wallet autocustodiado del usuario mediante flujo preautorizado y seguro. Se mostrará un QR para que el usuario pueda escanearlo.

Gestión de otras credenciales: Empleado. En este caso se pedirán datos adicionales y el QR se enviará por correo.

Salidas

- Credencial LEAR activa y verificable en la wallet del representante.
- Credenciales Employee opcionales para personal autorizado.
- Registro de emisión y firma por parte del conector institucional.
- Actualización de la *Bitstring Status List* para control de revocaciones.

Plazos / SLAs

- Validación de datos y firma institucional: ≤ 10 minutos.
- Entrega en wallet personal: inmediata (< 1 minuto tras firma).
- Sincronización en *Status List*: ≤ 1 hora.

Evidencias

- Log de autenticación eIDAS.
- Registro de emisión en Wallet Connector (hash y metadatos).
- Copia del esquema y credencial firmada (VC LEAR / Employee).
- Confirmación de recepción en wallet personal.
- Actualización de estado en la *Bitstring Status List*.

Los tres procesos (enrolamiento ISBE, enrolamiento on-chain y emisión de credenciales LEAR) operan de forma secuencial y modular, conformando el ciclo completo de identidad en ISBE:

1. El **enrolamiento ISBE** verifica la identidad del representante y registra su consentimiento.
2. El **enrolamiento on-chain** crea y publica la identidad descentralizada (*DID:isbe*).
3. La **emisión de credenciales** consolida la representación institucional mediante credenciales verificables (VCs).

6.4 Alta, cambio y baja de Representante (VC LEAR)

Objetivo. Asegurar que toda actuación del Participante se realiza a través de persona con poder vigente.

Ámbito/Roles. Participante (a través de su Representante saliente o responsable legal), TI, ISBE.

Entradas.

- Solicitud de **emisión/renovación/cambio/baja** de LEAR.
- Documentación de poderes o cese.
- En renovaciones: solicitud ≥ 30 días antes de la caducidad (ver 5.1 Regla 3).

Pasos.

1. **Recepción y verificación** de poderes/cese por TI/ISBE.
2. **Emisión/Renovación** de VC LEAR (o revocación/suspensión, según el caso).
3. **Publicación** del cambio de estado en el registro (sin PII) (ver 5.4).
4. **Propagación** a accesos vinculados (ver 5.3).

Salidas.

- LEAR vigente (emisión/renovación) o revocada/suspendida (cese/incidente).
- Accesos coherentes con el estado de la LEAR.

Plazos/SLA.

- Emisión/renovación: ≤ 2 días hábiles desde validación.
- Suspensión/Revocación: propagación a accesos ≤ 1 hora (ver 5.3 Regla 15).

Evidencias y publicación.

- Evidencia mínima de decisión (qué/quién/cuándo/regla).
- Publicación del **hecho** “con/sin Representante vigente”.

6.5 Alta, cambio y baja de Persona operativa (VC Empleado)

Objetivo. Habilitar, ajustar o retirar roles operativos de personas físicas con alcance limitado y trazable.

Ámbito/Roles. Participante (a través de su LEAR), Controlador de dominio, TI, TV (en su función de verificación).

Entradas.

- Solicitud del Participante (LEAR) indicando rol y alcance.
- Clasificación del rol (CRÍTICO/NO CRÍTICO) según punto 5.2 Regla 8.
- Selección del emisor según 5.2 Regla 9 (TI o auto-emisión si el dominio lo permite).

Pasos.

1. **Clasificar el rol** (CRÍTICO/NO CRÍTICO) y verificar si el dominio admite auto-emisión.
2. **Emisión** de la VC Empleado por TI (roles críticos) o por el Participante si está permitido (roles no críticos).
3. **Actualización del mapeo** credencial↔permisos del Participante (ver 5.3 Regla 17).
4. **Propagación** de accesos según el **estado** (ver 5.3).
5. **Publicación** del **hecho** “persona operativa habilitada por rol” (sin PII) (ver 5.4).

Salidas.

- VC Empleado vigente con rol/alcance definido o revocada/suspendida (cambio/cese).
- Accesos concedidos/ajustados/retirados en coherencia con el estado.

Plazos/SLA.

- Alta/cambio de accesos tras emisión/actualización: antes de fin del día hábil.
- Suspensión/Revocación: ≤ 1 hora hasta reflejarse en accesos.

Evidencias y publicación.

- Evidencia mínima de emisión/cambio/baja.
- Publicación del hecho y estado (sin PII) en el registro del dominio (si aplica).

6.6 Suspensión preventiva (riesgo o incumplimiento)

Objetivo. Contener el riesgo ante indicios razonables sin esperar a una revocación definitiva.

Ámbito/Roles. ISBE, Controlador de dominio, Participante (LEAR), TI/TV.

Entradas.

- Motivo: incidente, sospecha de fraude, incoherencia documental, incumplimiento.
- Evidencias iniciales (ticket, reporte, alerta).

Pasos.

1. **Declarar la suspensión** (sobre LEAR o VC Empleado) por ISBE/TI/Controlador, según el caso.
2. **Propagar bloqueo** a accesos (ver 5.3) y activar denegación por defecto en caso de dudas (ver 5.3 Regla 16).
3. **Notificar** al Participante (LEAR) y abrir plan de remediación con acciones y plazos.
4. **Investigar y resolver**: levantar suspensión (si se justificó) o revocar (si se confirma el incumplimiento).
5. **Publicar** el nuevo estado (sin PII) y cerrar el caso con evidencia mínima.

Salidas.

- Identidad/credencial suspendida, restaurada o revocada.
- Accesos bloqueados/restaurados.

Plazos/SLA.

- Bloqueo de accesos tras suspensión: ≤ 1 hora.
- Plan de remediación: ≤ 5 días hábiles (salvo casos complejos motivados).

Evidencias y publicación.

- Orden de suspensión, plan, resolución y traza de cambios.
- Publicación del estado actualizado (sin PII).

6.7 Baja (offboarding)

Objetivo. Retirar de forma ordenada y trazable la condición de Participante, de Representante o de Persona operativa.

Ámbito/Roles. Participante (LEAR), ISBE, Controlador de dominio, TI, TV.

Entradas.

- Solicitud del Participante (baja voluntaria) o expediente por incumplimiento (baja no voluntaria).
- Relación de credenciales vigentes y accesos asociados.

Pasos.

1. **Decisión de baja** (voluntaria o por incumplimiento, tras expediente).
2. **Revocar** VC LEAR y/o VC Empleado afectados.

3. **Retirar accesos** vinculados (ver 5.3).
4. **Publicar** el **hecho** de baja en los registros pertinentes (sin PII) (ver 5.4).
5. **Cierre administrativo**: archivo de evidencias y notificación a las partes.

Salidas.

- Participante/representante/persona operativa en baja.
- Accesos retirados y registros actualizados.

Plazos/SLA.

- Retirada de accesos por baja: ≤ 1 hora desde revocación.
- Publicación del hecho: mismo día hábil.

Evidencias y publicación.

- Resolución de baja (quién, cuándo, causa).
- Publicación del estado actualizado (sin PII) e histórico de cambios.

6.8 Gestión de incidentes de identidad (credenciales, accesos, mapeo)

Objetivo. Detectar, contener, resolver y aprender de incidentes que afecten a identidad/credenciales/accesos.

Ámbito/Roles. Participante (LEAR), ISBE, Controlador de dominio, TI/TV, Órgano de control.

Entradas.

- Detección: alertas del sistema, reporte del TV/TI, auditoría, usuario.
- Datos del incidente (qué, cuándo, alcance, sistemas afectados).

Pasos.

1. **Clasificar** el incidente (impacto bajo/medio/alto) y contener (suspensión preventiva si procede, ver 6.4).
2. **Bloquear accesos afectados** (ver 5.3) y activar denegación por defecto si hay dudas.
3. **Investigar** (causas, credenciales implicadas, fallos de mapeo o de proceso).
4. **Corregir** (revocar/emitir credenciales, actualizar mapeo, reforzar controles).
5. **Cerrar** con **informe** (resumen, línea de tiempo, medidas adoptadas y lecciones aprendidas).
6. **Notificar** a las partes pertinentes y, si procede, al Órgano de control/auditoría.

Salidas.

- Estado de identidades/credenciales normalizado.
- Accesos coherentes con el estado y mapeo actualizado.
- Informe de cierre.

Plazos/SLA.

- **Contención** (bloqueo/suspensión): ≤ 1 hora.
- **Cierre preliminar**: ≤ 5 días hábiles; cierre definitivo con acciones preventivas si aplica.

Evidencias y publicación.

- Evidencia mínima de cada decisión.
- Si impacta estatus público (p. ej., suspensión de TI/TV por causa de identidad), publicación del hecho (sin PII).

6.9 Revisión periódica (anual o por evento)

Objetivo. Mantener vigentes y adecuadas las identidades y credenciales.

Ámbito/Roles. Participante (LEAR), ISBE, Controlador de dominio.

Entradas.

- Calendario de revisión (al menos anual y por evento relevante).
- Listado de LEAR y VC Empleado vigentes y por caducar.

Pasos.

1. **Verificar** poderes de representación y situación del Participante.
2. **Revisar** roles operativos: necesidad, alcance, vigencia.
3. **Actualizar** (renovar, ajustar alcance, revocar si procede).
4. **Reconciliar mapeo** credencial↔permisos (ver §5.3 Regla 17).
5. **Registrar** evidencias y **publicar** hechos/estados (sin PII).

Salidas.

- Credenciales y accesos alineados con la realidad organizativa.
- Riesgo de accesos residuales reducido.

Plazos/SLA.

- Cierre de revisión anual: 30 días naturales desde inicio.
- Revisiones por evento: ≤ 5 días hábiles desde el evento.

Evidencias y publicación.

- Acta/resumen de revisión y decisiones.
- Actualizaciones en registros (sin PII) e histórico.

7. Supervisión, revisión y actualización

Este punto define cómo se controla el cumplimiento de INF1050, cada cuánto se revisa y cómo se actualiza la política cuando cambian las condiciones.

7.1 Objetivo y alcance de la supervisión

- **Objetivo:** asegurar que la gestión de identidades, credenciales y accesos se aplica de forma homogénea.
- **Ámbito:** todos los Participantes, dominios/TA, TI/TV y entornos (preproducción y producción).

7.2 Reporting operativo (paneles y periodicidad)

- **Panel mensual por dominio** consolidado por ISBE, con al menos:
  - Altas/bajas de Participantes y representantes.
  - VC Empleado emitidas / renovadas / revocadas por rol.
  - Latencia de propagación a accesos (ver 5.3):
    - Suspensión/Revocación → acceso bloqueado (P95 ≤ 60 min).
    - Alta/renovación → acceso activo (antes de fin de día hábil, P95).
  - Inconsistencias detectadas (activación de denegación por defecto) y tiempo de resolución.
  - Excepciones activas y vencidas (ver 5.5).
  - Cumplimiento de publicación en registros (ver 5.4) y de revisión anual.
- **Informe trimestral** a “Junta ISBE”: tendencias, desviaciones y medidas correctoras.
- **Comunicaciones ad-hoc** ante incidentes relevantes o incumplimientos graves.

7.3 Indicadores y umbrales (KPI mínimos)

- **Tiempo de alta de miembro** (desde expediente completo hasta “miembro vigente”): ≤ 10 días hábiles.
- **Emisión/renovación de VC LEAR** tras validación: ≤ 2 días hábiles.
- **Propagación suspensión/revocación a accesos**: P95 ≤ 60 min (ver 5.3 Regla 15).
- **Alta/renovación a accesos**: antes de fin de día hábil (o umbral más estricto si lo fija el dominio).
- **% revisiones anuales completadas en plazo** (miembros y roles): ≥ 95%.
- **Reconciliación mapeo credencial a permisos** (ver 5.3 Regla 17): ≥ 99% mensual.
- **Incidentes de identidad** (frecuencia) y **tiempo de cierre preliminar**: ≤ 5 días hábiles.
- **Errores de publicación** (registros): corrección ≤ 2 días hábiles.

Incumplimiento de KPI activa **medidas correctoras** (7.5).

7.4 Auditorías (ordinarias y ad-hoc)

- **Ordinarias:** anuales, con muestreo reforzado de roles críticos y de dominios con mayor riesgo/volumen.
- **Ad-hoc (triggers):**
  - Incidente grave o repetido en identidad/accesos.
  - Brecha de KPI persistente (dos meses consecutivos).
  - Cambio normativo relevante (eIDAS 2.0, EUDIW/ARF, NIS2).
  - Propuesta formal de participante que evidencie disfunciones.
- **Alcance mínimo:** evidencias, clasificación de roles (5.2 Regla 8), quién emite VC Empleado (5.2 Regla 9), propagación a accesos (5.3), publicación en registros (5.4) y gestión de excepciones (5.5).

7.5 Medidas correctoras y escalado

Escalado proporcional y documentado:

1. **Advertencia** con **plan de remediación** (acciones y plazos, típicamente ≤ 5 días hábiles).
2. **Suspensión temporal** de emisión/verificación o de accesos afectados (ver 6.4).
3. **Retirada** del estatus de TI/TV o baja del dominio/miembro (ver 6.5), si persiste el incumplimiento.

- **Derecho de alegaciones** y revisión por ISBE.
- Todo queda **trazado** con evidencia mínima y publicado el hecho (sin PII) cuando proceda.

7.6 Revisión y actualización de INF1050 (periodicidad y triggers)

- **Revisión ordinaria:** anual (cada 12 meses).
- **Triggers de revisión extraordinaria:**
  - Cambios en eIDAS 2.0, EUDIW/ARF, NIS2 o normativa sectorial aplicable.
  - Aparición de nuevos tipos de credenciales o roles no cubiertos.
  - Incidente mayor o patrón de incumplimientos que evidencie un vacío en la política.
  - **Propuesta formal** de un miembro o **controlador de dominio** (p. ej., cambios en la política de aceptación de casos de uso).
- **Proceso de cambio:**
  - **Propuesta** (ISBE o controlador de dominio), con análisis de impacto.
  - **Consulta interna** a miembros (15 días).
  - **Aprobación** por ISBE y publicación.
  - **Ventana de gracia** para adaptación: 60 días naturales (salvo cambios urgentes de seguridad, vigencia inmediata).
  - **Actualización** de artefactos y documentos relacionados.

7.7 Gestión de versiones y comunicación

- **Versionado** (identificador de versión y tabla de cambios).

- **Entrada en vigor** de cada versión y derogación de la anterior.
- **Comunicación** a miembros y controladores de dominio: circular y sesión informativa.
- **Publicación** de la versión vigente en el registro raíz (hecho, sin PII).

7.8 Resumen práctico de roles en la supervisión

- **ISBE (Entidad Gestora):** lidera supervisión, consolida paneles, ejecuta auditorías y aprueba actualizaciones.
- **Controladores de dominio:** aportan datos mensuales y aplican medidas en su ámbito.
- **Miembros (a través de LEAR):** mantienen mapeo actualizado (ver 5.3 Regla 17), responden requerimientos en ≤ 3 días hábiles y ejecutan remediaciones.
- **Órgano de control/auditoría:** verifica de forma independiente y eleva recomendaciones.

8. Anexos

No aplica.